

SLAM Projet LyonPalme Planning d'entraînements

Groupe : Aragorn, Fatih, Bastian

Analyse du risque :

Application planning d'entraînement :

Use Case	D (Disponibilité)	I (Intégrité)	C (Confidentialité)	P (Nonrépudiation)
Se connecter (Entraîneur)			**	
Visualiser le planning des entraîneurs				
Signaler une indisponibilité		**		*
Proposer un échange d'horaires		*		
Créer un planning d'entraînement (Responsable)		**		
Modifier le planning d'entraînement (Responsable)		**		
Changer le mot de passe (Responsable)			*	
Créer un entraînement (Responsable)		*		
Modifier/supprimer un entraînement (Responsable)		**		*
Cliquer sur « mot de passe oublié » (Entraîneur)				
Visualiser les entraînements sur une période (Entraîneur)				
Ajout automatiquement dans google agenda		*		*

Analyse des besoins de sécurité aux événements redoutés :

<u>Evènement redoutés :</u>	<u>Impact métier :</u>	<u>Sévérité :</u>
L'application ne répond pas	Impossible de se connecter pour voir le planning	*
Le planning ne s'affiche pas	Impossible de voir les entraînements et qui est assigné à chaque entraînements	*
Le planning ne peut pas être modifié	Mauvaise entraineur assigné -> potentiel manque d'entraineur pour des entraînements	*
Usurpation	Un nageur usurpe l'identité d'un entraineur et modifie le planning	**
Attaque des données personnelles stockées	Une tierce personne malveillante, récupère les données personnelles stockées dans la base de données	**

Abuser Stories :

1. L'application ne répond pas (Attaque DDOS)

En tant qu'attaquant, je veux surcharger l'application avec un grand nombre de requêtes, afin de la rendre indisponible pour les utilisateurs.

Contremesures :

- Limitation de x requêtes par minute par utilisateur

2. Le planning ne s'affiche pas (Corruption ou suppression des données)

En tant qu'attaquant, je veux corrompre ou supprimer les données du planning, afin d'empêcher les utilisateurs d'accéder à leurs entraînements.

Contremesures :

- Activer les Soft Deletes (permet d'éviter la suppression définitive)
- Sauvegarde automatique de la BDD (Avec Laravel Backup)

3. Le planning ne peut pas être modifié

En tant qu'attaquant, je veux empêcher l'entraîneur responsable planning de modifier le planning, afin de désorganiser la gestion des entraînements.

Contremesures :

- Mettre en place des rôles et des permissions pour les utilisateurs
- Mettre en place de logs pour voir qui a changé quoi

4. Usurpation d'identité (Escalade de privilèges)

En tant qu'attaquant, je veux usurper l'identité d'un entraîneur, afin de modifier le planning.

Contremesures :

- Activer l'2FA (Authentification à deux facteurs)
- Vérifier le rôle de l'utilisateur avant d'accéder à la page

5. Attaque des données personnelles stockées (Vol de données)

En tant qu'attaquant, je veux récupérer les données personnelles des utilisateurs, afin de les exploiter ou/et les revendre illégalement.

Contremesures :

- Chiffrement des données sensibles et personnels dans la BDD
- Ne pas stocker les mots de passe en clair